

BEFORE Placeholder

AFTER

Incident Notification & Communications Control Baseline (Tiered)

Document classification: Internal

Baseline owner: Security Incident Lead (with Security Engineering/Architecture)

Privacy owner: Data Protection Officer / Privacy Officer

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

Define minimum requirements for supplier incident notification and communications to ensure timely awareness, effective containment, and compliance/privacy response where applicable.

2. Scope

Applies to suppliers that:

- process/store/transmit organisational data, and/or
- provide SaaS/admin services used by the organisation, and/or
- integrate into organisational systems (API/agent/connectivity), and/or
- support business-critical services.

Covers:

- security incidents (confidentiality/integrity compromise, credential compromise)
- availability incidents (material outages) where they impact critical services

- privacy incidents involving personal data

3. Control statements (tiered)

3.1 Tier Critical (Tier 1) — MUST controls

Critical suppliers MUST:

1. Provide **named incident communications contacts** (primary and secondary) with 24x7 reachability where the service is critical.
2. Commit to **time-bound notification** for material incidents affecting service scope (contracted or formally agreed).
3. Provide **structured updates** during active incidents:
 - initial summary
 - impact scope (systems, tenants, data types)
 - containment actions taken
 - recommended customer actions (e.g., key rotation, access restrictions)
 - update cadence and next update time
4. Provide **customer-relevant IOCs/detection guidance** where available.
5. Provide a **post-incident report** for material incidents/outages:
 - timeline, root cause, corrective actions, and target dates.
6. Support **privacy breach assessment** when personal data is involved:
 - data categories, volume (if known), residency, sub-processors involved
 - notification timing and support information.

Critical suppliers SHOULD:

- provide a status page or equivalent communications channel
- support joint incident reviews for major incidents
- provide a dedicated channel for emergency access disablement or integration suspension requests

3.2 Tier Important (Tier 2) — MUST controls

Important suppliers MUST:

- provide a named security/incident contact
- notify material incidents affecting our service scope in a timely manner (commitment agreed)
- provide a basic incident summary, impact statement, and next update time
- cooperate with investigations and provide logs/evidence where feasible

Important suppliers SHOULD:

- provide RCA summary for material incidents
- provide detection guidance/IOCs where relevant

3.3 Tier Low (Tier 3) — proportionate controls

Low suppliers SHOULD:

- provide a security contact and reasonable notification for incidents affecting the service
- cooperate with basic information requests

4. Minimum incident information requirements (supplier-provided)

For Tier Critical incidents (Severity 1/2), supplier MUST provide:

- Incident start time (earliest known) and detection time (timezone)
- Description of what happened and current status (ongoing/contained/recovered)
- Affected systems/environments/regions
- Confirmation of whether our tenant/accounts/data are impacted (or when it will be confirmed)
- Data types potentially affected (PII/financial/auth secrets)
- Whether any credentials/tokens/certificates may be compromised; rotation guidance
- Containment actions already taken and next planned actions
- Update cadence and next update time

- IOCs/detection guidance (if available)
- Sub-processor involvement (if any)

5. Communications channels and cadence

MUST (Critical):

- Define the approved notification channels (email + phone bridge or equivalent).
- Define escalation path for non-responsiveness.
- Agree a minimum update cadence during active incidents (e.g., daily or more frequently for Severity 1).

SHOULD:

- Maintain a pre-agreed incident distribution list and on-call path (internal).

6. Contractual alignment (minimum clauses to capture)

For Critical suppliers, contracts SHOULD capture:

- notification timeframe for material incidents
- cooperation obligations (logs, evidence, investigation updates)
- sub-processor incident notification flow-down
- post-incident report obligations
- right to request audit/evidence for material incidents (where applicable)

7. Validation steps (how to prove it)

For each Critical/Important supplier, record evidence location and complete checks.

Contacts: [] Primary and secondary incident contact details captured and validated

[] Contact update cadence defined (e.g., quarterly verification)

Evidence location:

Commitments: ☐ Notification time commitment documented (contracted or agreed)

☐ Update cadence expectation documented

Evidence location:

Process: ☐ Supplier IR process summary received (high level)

☐ Supplier agrees to provide incident questionnaire responses on request

Evidence location:

History: ☐ Any incidents in period reviewed; supplier performance against commitments recorded

Evidence location:

Privacy (if personal data in scope): ☐ DPO/Privacy Officer engaged; breach assessment support requirements confirmed

Evidence location:

8. Exceptions

If a Tier Critical supplier cannot commit to time-bound notification or refuses cooperation:

- treat as a material gap
- escalate per governance for decision (do not proceed / restrict / exception with compensating controls)
- document compensating controls only if they meaningfully reduce risk (e.g., reduced scope, no sensitive data, no privileged access)

9. Sign-off (per supplier)

Supplier: _____ Service: _____ Tier: ☐ Critical ☐
Important ☐ Low

Security Incident Lead (role title): _____ Date: _____ Security
Engineering/Architecture (role title): _____ Date: _____ Business Service Owner (role
title): _____ Date: _____ DPO/Privacy Officer (if personal data):
_____ Date: _____